

Scentra

Roadmap de robustez, seguridad, acciones por modulo y montaje Admin

Generado: 2026-05-20 22:30 | Proyecto: Scentra AI SaaS

Este documento resume acciones recomendadas para convertir Scentra en una plataforma SaaS mas segura, operable, robusta y vendible. Incluye recomendaciones por modulo, CAPTCHA, Admin, observabilidad y fases de implementacion.

1. Resumen ejecutivo

Scentra ya tiene una base SaaS funcional: portal cliente, API multi-tenant, worker, admin-frontend inicial, rutas admin, integraciones Meta, CRM, Inbox, AI Agents, diagnosticos y billing base. El siguiente salto no es solo agregar pantallas: es robustecer operacion, seguridad, observabilidad, automatizacion y control administrativo para venta real.

- Prioridad 1: seguridad de acceso, CAPTCHA, rate limiting, 2FA y hardening de sesiones.
- Prioridad 2: montar Scentra Admin en produccion para controlar clientes, planes, suscripciones, flags, soporte y operaciones.
- Prioridad 3: cerrar robustez operacional: colas, reintentos, dead-letter, auditoria, health checks y alertas.
- Prioridad 4: mejorar accionabilidad por modulo: Inbox, CRM, Campaigns, Broadcast, Integraciones, Knowledge y AI Agents.
- Prioridad 5: preparar monetizacion: Stripe/MercadoPago, trials, limites reales, bloqueo por impago y facturacion.

2. Recomendacion CAPTCHA

Para Scentra recomiendo Cloudflare Turnstile como primera opcion. Es menos friccionante que los CAPTCHAs visuales, tiene modo managed/invisible, puede usarse aunque el sitio no este detras de Cloudflare y su plan Free permite verificaciones/challenges ilimitados con hasta 20 widgets por cuenta. reCAPTCHA es solido, pero la capa gratis actual es de 10.000 assessments mensuales por organizacion; despues empieza el cobro. hCaptcha Basic es gratis y bueno en privacidad, pero su experiencia sin friccion avanzada queda en Pro/Enterprise.

- Implementar Turnstile en registro, login, recuperar clave, creacion de demo y login admin.
- Validar siempre el token en backend. Nunca confiar solo en el frontend.
- Combinar CAPTCHA con rate limiting por IP, email, tenant y endpoint. El CAPTCHA solo no alcanza.
- Agregar modo 'adaptive': pedir CAPTCHA solo despues de intentos fallidos, IP sospechosa o acciones sensibles.
- Variables sugeridas: TURNSTILE_SITE_KEY en frontend y TURNSTILE_SECRET_KEY en backend runtime secret.

Proveedor	Plan Gratuito	Características	Limitaciones
Cloudflare Turnstile	Free, hasta 20 widgets, challenges/verificaciones ilimitadas	Baja friccion, buena accesibilidad, ideal para SaaS	20 widgets por cuenta en Free
Google reCAPTCHA	10.000 assessments gratis/mes por organizacion	Muy conocido, scores y ecosistema Google	Puede generar costo rapido al crecer
hCaptcha	Basic Free; Pro incluye 100K evals/mes	Privacidad y cobertura global	UX avanzada/passive mode en planes pagos

3. Plan tecnico CAPTCHA para Scentra

La implementacion debe ser transversal y configurable, no amarrada a un solo formulario.

- Backend: crear app_saas/security/captcha.py con verify_captcha(provider, token, ip, action).
- Backend: agregar variables SAAS_CAPTCHA_PROVIDER=turnstile, TURNSTILE_SECRET_KEY, SAAS_CAPTCHA_ENABLED=true.
- Frontend cliente: componente CaptchaWidget reutilizable para register/login/reset-password.
- Admin frontend: CaptchaWidget en login admin y bootstrap si se habilita temporalmente.

- Endpoints a proteger: /auth/register, /auth/login, /auth/reset, /admin/auth/login, /admin/auth/bootstrap, webhooks/debug si se exponen.
- Agregar tabla `saas_security_events`: tipo, IP, email, user_agent, resultado CAPTCHA, motivo bloqueo.
- Rate limiting: login por email+IP, register por IP, API keys por tenant, webhooks por endpoint_key.

4. Estado actual del Admin

El proyecto ya tiene carpeta admin-frontend y backend `app_saas/admin/router.py`. La API admin incluye login, bootstrap local, overview, tenants, planes, suscripciones, feature flags, auditoria, operaciones de colas e impersonacion. No estamos empezando de cero: falta montarlo correctamente en Coolify y cerrar seguridad/operacion de produccion.

- Existe admin-frontend con Dockerfile y variables `VITE_API_BASE` / `VITE_CLIENT_APP_BASE`.
- Existe backend `/saas/v1/admin` con roles `platform_admin`, `superadmin`, `billing_admin` y `support`.
- Existe migracion `016_saas_platform_admin.sql` para plataforma admin, feature flags y plan metadata.
- El bootstrap de primer admin se bloquea en produccion; para produccion hace falta seed seguro o SQL/manual controlado.
- Debe desplegarse como app separada: `admin.scentra-ai.online`, usando la misma API `api.scentra-ai.online`.

5. Checklist para montar Admin en Coolify

Configuracion recomendada para dejar `admin.scentra-ai.online` operativo sin duplicar backend.

- Crear una app nueva en Coolify llamada Scentra Admin Frontend.
- Usar el mismo repositorio y rama main.
- Build Pack: Dockerfile.
- Base Directory: `/admin-frontend` si el repositorio raiz en Coolify ya es `saas-version`; si el repo contiene `saas-version`, usar `/saas-version/admin-frontend`.
- Dockerfile Location: `/admin-frontend/Dockerfile` o `/saas-version/admin-frontend/Dockerfile` segun base real.
- Dominio: `https://admin.scentra-ai.online`.
- Build args/env buildtime: `VITE_API_BASE=https://api.scentra-ai.online`, `VITE_CLIENT_APP_BASE=https://app.scentra-ai.online`.
- Backend CORS: incluir `https://admin.scentra-ai.online` en `SAAS_CORS_ORIGINS`.
- Ejecutar migraciones antes del primer login admin.
- Crear primer platform admin en produccion por SQL controlado o comando interno seguro; no dejar bootstrap abierto.

6. Admin: faltantes antes de venta real

La base existe, pero para operacion real conviene completar estas piezas.

- 2FA obligatorio para superadmin/platform_admin.
- IP allowlist opcional para admin.scentra-ai.online.
- Auditoria reforzada: cambios de plan, impersonacion, cambios de tokens, feature flags, reintentos de workers.
- Pantalla de health global: API, worker, DB, colas, Meta, AI Gateway, storage y pagos.
- Gestion completa de planes: modulos, limites AI Agents, memoria, usuarios, integraciones, storage, webhooks y broadcasts.
- Bloqueo por impago/trial vencido con mensajes claros en portal cliente.
- Modulo billing: Stripe/MercadoPago, facturas, recibos, eventos webhook, retry de cobro y creditos manuales.
- Soporte seguro: impersonacion con razon obligatoria, expiracion corta y banner visible en cliente.
- Alertas operativas por Slack/Email: webhooks fallidos, jobs fallidos, consumo anomalo, tokens Meta expirados.

7. Roadmap por secciones

Acciones recomendadas para que el producto se sienta mas robusto, vendible y operable.

Seccion	Acciones recomendadas y pendientes	Prioridad
Dashboard	KPIs reales por periodo, conversion funnel, salud de canales, alertas de plan, revenue, top agentes, cohortes	Alta
Inbox	WebSocket realtime, SLA/timers, asignacion de agentes, estados Meta, respuestas rapidas, adjuntos, audio, sonido, cola de no leidos	Alta
Comentarios	Vista tipo Meta Business Suite, post preview, comentario resaltado, responder/reaccionar, IA por tono y reglas	Alta
CRM	Campos personalizados, scoring, merge duplicados, tareas, recordatorios, timeline completo, import/export	Alta
Campanas CRM	Builder visual, simulador, aprobaciones, quiet hours, A/B, throttling, tags dinamicos, triggers por eventos	Alta
Mensajería masiva	Audiencias, opt-out, plantillas por estado Meta, rate control, calendario, analitica por envio/lectura/respuesta	Alta
Integraciones	OAuth/refresh, health checks, auto-repair, rotacion de tokens, diagnostico por tenant, eliminar endpoints asociado	Alta
Knowledge Base	Upload real, crawling, vector search, freshness score, citas de fuente, RAG evals, versionado	Alta

Modulo	Funciones robustas sugeridas	Prioridad
AI Agents	Preflight, presupuesto, A/B, score salud, memoria import/export, evals, tool approvals, prompt versioning	Alta
Ads Manager	Lead Ads, comentarios de anuncios, ROAS, UTM, sync Meta Ads, sugerencias AI de presupuesto	Media
Ajustes	2FA, sesiones, API keys con rotacion, webhooks salientes, RBAC granular, perfil, equipos	Alta
Admin	Tenants, planes, billing, flags, impersonacion, auditoria, operaciones, soporte y colas	Alta
Mobile	Push notifications, inbox ligero, aprobaciones, respuestas rapidas, dashboards compactos	Media

8. Inbox y omnicanal: acciones de alto impacto

El Inbox debe convertirse en el centro operativo, no solo un visor de mensajes.

- Realtime por WebSocket/SSE para mensajes, estados, typing, asignaciones y comentarios.
- Bandejas: todos, asignados a mi, sin leer, urgente, IA en control, humano en control, fallidos.
- SLA por conversacion: primera respuesta, tiempo sin seguimiento, riesgo de abandono.
- Routing automatico por reglas: canal, etiqueta, horario, agente disponible, tipo de cliente.
- Modo supervisor: ver conversaciones activas, intervenir, reasignar, auditar takeover.
- Historial de estados Meta: enviado, entregado, leído, fallido, motivo de fallo.
- Plantillas contextuales: si pasaron 24h en WhatsApp, sugerir template aprobada en vez de texto libre.
- Spam/abuse detection y bloqueo por cliente/canal.

9. CRM: robustez comercial

El CRM debe alimentar IA, remarketing, campa?as y priorizacion.

- Lead scoring automatico por intencion, urgencia, valor potencial y engagement.
- Pipeline configurable por industria: ecommerce, restaurante, hotel, clinica, inmobiliaria, legal.
- Campos personalizados por tenant y formularios dinamicos.
- Deduplicacion por telefono, Instagram PSID, email y nombre probable.
- Tareas y follow-ups: llamadas, cotizaciones, pagos, reservas, visitas.
- Historial unificado: mensajes, comentarios, compras, productos vistos, campa?as, notas y eventos AI.
- Segmentos guardados para campa?as y remarketing.

10. Campanas, triggers y remarketing

Aqui esta gran parte del valor economico de Scentra.

- Trigger simulator: probar palabras clave, tiempos y condiciones antes de activar.
- Versionado de triggers y rollback si una regla genera malos resultados.
- Remarketing por etapas con salida automatica cuando cambia el estado del cliente.
- Control anti-spam: frecuencia maxima, ventanas horarias, cooldown y opt-out.
- A/B testing de copies, plantillas y tiempos.
- Alertas cuando una template Meta es rechazada y sugerencia AI de correccion.
- Calendario de difusiones con limites por plan y canal.

11. AI Agents: siguiente nivel

Los agentes no deben ser solo chatbots. Deben observar, recomendar y ejecutar con aprobacion.

- Prompt/version registry por agente: historial, autor, fecha, resultados y rollback.
- Evals automatizadas: conversaciones simuladas por industria antes de activar.
- Tool permissions por rol y por agente: leer, escribir, proponer, ejecutar.
- Human approval layer obligatorio para acciones sensibles: descuentos, pagos, datos personales, salud/legal/finanzas.
- AI cost guardrails: presupuesto mensual por agente y por tenant.
- Memory governance: retencion, exportacion, borrado, PII redaction y limites por plan.
- Recommendation engine: priorizar acciones por impacto estimado y confianza.
- Agent marketplace interno: plantillas verticales para restaurantes, hoteles, clinicas, inmobiliarias, educacion, legal, seguros y servicios.

12. Knowledge Base y RAG

Para que la IA no dependa solo del system prompt, la base de conocimiento debe ser verificable y medible.

- Carga de PDF/TXT/CSV/URLs con estado: pendiente, procesando, indexado, error.
- Vector search por tenant con aislamiento fuerte.
- Crawling programado de URLs con deteccion de cambios.
- Citas de fuente en respuestas internas y modo 'no responder si no hay fuente'.
- RAG evals: tasa de respuesta con fuente, freshness, documentos sin uso, preguntas sin respuesta.
- Permisos por documento: publico para agente, privado interno, solo admin.

13. Seguridad y cumplimiento

Antes de escalar clientes reales, hay que endurecer acceso, secretos y trazabilidad.

- CAPTCHA + rate limiting en login/register/reset/admin.
- 2FA: obligatorio para admin plataforma; opcional/por plan para tenants.
- Rotacion de refresh tokens y revocacion de sesiones desde Ajustes > Seguridad.
- CSP, headers de seguridad, CORS estricto por dominio, cookies seguras si se migra a cookie auth.
- Cifrado de secretos por tenant y no devolver nunca tokens completos al navegador.
- Audit log inmutable para acciones criticas.
- Backups automaticos con prueba de restauracion.
- Politicas de retencion/borrado por tenant, especialmente mensajes y adjuntos.

14. Operaciones, observabilidad y self-healing

La robustez real se ve cuando algo falla y el sistema se recupera o explica el fallo.

- Worker separado y monitoreado: outbound, webhooks, triggers, token refresh, knowledge indexing.
- Dead-letter queues para eventos que fallan varias veces.

- Reintentos con backoff y motivo claro por job.
- Dashboard de health: API, DB, worker, Meta, AI providers, storage, billing.
- Alertas por errores Meta recurrentes: token invalido, permisos, subscribed_apps, WABA no accesible.
- Tracing por mensaje: inbound webhook -> conversation -> AI -> outbound -> status.
- Logs con correlation_id por tenant y conversacion.

15. Infraestructura recomendada para produccion

Mantener Coolify esta bien para esta etapa, pero con separacion clara por servicio.

- Apps separadas: API/worker, frontend cliente, frontend admin. Misma base Postgres centralizada.
- Object storage para medios: S3 compatible, Cloudflare R2 o MinIO gestionado.
- Redis para rate limits, locks, colas ligeras, cache de modelos y sesiones si se requiere.
- Backups de Postgres diarios y snapshots antes de migraciones.
- CI/CD con build de frontend, compileall backend, migraciones dry-run y smoke tests.
- Monitoreo externo: UptimeRobot/BetterStack o similar para app, admin, api y webhooks.

16. Plan de fases sugerido

Orden recomendado para no construir muchas cosas encima de una base insegura.

- Fase 1: Seguridad base: Turnstile, rate limiting, 2FA admin, headers, auditoria critica.
- Fase 2: Montar Scentra Admin: dominio, build, admin seed, CORS, planes, feature flags, subscriptions.
- Fase 3: Observabilidad: health global, colas, dead-letter, correlation IDs, diagnosticos por canal.
- Fase 4: Inbox/CRM robusto: realtime, SLA, asignaciones, scoring, tareas, estados Meta completos.
- Fase 5: Monetizacion: Stripe/MercadoPago, trials, bloqueo por impago, facturas, creditos.
- Fase 6: AI enterprise: evals, prompt versions, tool approval, memory governance, analytics de costo.
- Fase 7: Verticalizacion: presets por industria, plantillas, pipelines, agentes y workflows por sector.

17. Fuentes consultadas para CAPTCHA

Referencias oficiales revisadas el 2026-05-20.

- Cloudflare Turnstile Plans: <https://developers.cloudflare.com/turnstile/plans/>
- Cloudflare Turnstile Get Started: <https://developers.cloudflare.com/turnstile/get-started/>
- Google reCAPTCHA Billing/Pricing: <https://cloud.google.com/recaptcha/docs/billing-information>
- Google reCAPTCHA Enterprise Pricing: <https://cloud.google.com/security/products/recaptcha-enterprise/pricing>
- hCaptcha Pricing: <https://www.hcaptcha.com/pricing>